

API Specification

Base URL: `https://api.salestorm.example/v1` · Format: JSON over HTTPS (TLS 1.2+)
Authentication: Authorization: Bearer <JWT> (OAuth2/OIDC, 15-min access token, `customer` / `admin` / `support` scopes).
Common headers: `X-Request-Id` / `traceparent` (tracing), `Idempotency-Key` (required on all mutating customer calls that create business transactions).

1. Endpoint Summary

#	Method	Endpoint	Purpose	Auth	Idempotent
1	GET	<code>/sales/{saleId}</code>	Sale details, status, approximate stock banner	Public/Customer	yes
2	GET	<code>/products/{productId}</code>	Product detail (CDN-cached)	Public	yes
3	POST	<code>/sales/{saleId}/queue</code>	Join waiting room, get queue token	Customer	via key
4	GET	<code>/sales/{saleId}/queue/{token}</code>	Queue position / admission status	Customer	yes
5	POST	<code>/reservations</code>	Buy Now - reserve inventory	Customer + admission token	Idempotency-Key
6	GET	<code>/reservations/{id}</code>	Reservation status and expiry	Customer (owner)	yes
7	DELETE	<code>/reservations/{id}</code>	Cancel/release reservation	Customer (owner)	yes
8	PUT/POST	<code>/cart/items</code>	Cart operations	Customer	yes
9	POST	<code>/checkout</code>	Price + create payment for a reservation	Customer	Idempotency-Key
10	GET	<code>/payments/{id}</code>	Payment status	Customer (owner)	yes
11	POST	<code>/payments/webhook/{provider}</code>	Gateway callback	HMAC signature	dedupe by event id
12	GET	<code>/orders/{id}</code>	Order details & timeline	Customer (owner)	yes
13	POST	<code>/orders/{id}/cancel</code>	Cancel order	Customer/Support	Idempotency-Key
14	GET	<code>/orders/{id}/tracking</code>	Shipment tracking	Customer (owner)	yes
15	POST	<code>/admin/sales/{id}/open</code>	Open sale, initialise stock gate	Admin	yes
16	POST	<code>/admin/reconciliation/run</code>	Trigger reconciliation	Admin	yes

2. Detailed Contracts

2.1 POST `/reservations` (Buy Now)

Request

```
POST /v1/reservations
Authorization: Bearer <jwt>
Idempotency-Key: 7c9e6679-7425-40de-944b-e07fc1f90ae7
X-Admission-Token: adm_8f3a...
Content-Type: application/json

{ "saleId": "b1c...", "productId": "a22...", "quantity": 1 }
```

Responses

Status	Meaning	Body
201 Created	Reserved	<code>{"reservationId":"...", "state":"RESERVED", "expiresAt":"2026-10-05T11:10:00Z"}</code>

200 OK	Duplicate replay of earlier success	same body + "replayed":true
202 Accepted	Still in waiting room	{"queuePosition":1432,"retryAfterSeconds":3}
400 Bad Request	Validation error (qty ≤ 0, missing key)	error object
401 / 403	Not authenticated / not allowed / no admission token	error object
409 Conflict	OUT_OF_STOCK or LIMIT_EXCEEDED or SALE_NOT_ACTIVE	{"code":"OUT_OF_STOCK"}
422	Idempotency key reused with a different payload	error object
429 Too Many Requests	Rate limited; Retry-After header	error object
503	Dependency unavailable (retryable)	error object

2.2 POST /checkout

```
// Request
{ "reservationId": "...", "paymentMethodToken": "tok_...", "couponCode": "FLASH10" }
// 202 Accepted
{ "paymentId": "...", "status": "PENDING", "redirectUrl": "https://gateway/3ds/...", "reservationExpiresAt": "..." }
```

Errors: 404 reservation not found · 409 reservation not in RESERVED / PAYMENT_PENDING (expired/released) · 422 amount mismatch · 502/504 gateway problem → payment stays PENDING, client polls GET /payments/{id}.

2.3 GET /payments/{id}

200 {"paymentId":"...", "status":"SUCCEEDED", "orderId":"...|null"} - orderId is null until the order is created (UI shows "confirming order").

2.4 POST /payments/webhook/{provider}

Headers: X-Signature (HMAC-SHA256 of body). Body: gateway event with event_id, merchant_ref, status. Responses: 200 (processed or duplicate) · 401 bad signature · 5xx makes gateway retry. Processing is idempotent via gateway_event.

2.4b GET /orders/{id}

```
200 { "orderId":"...", "state":"CONFIRMED", "items":[{"productId":"...", "quantity":1, "unitPrice":999.00}],
      "totalAmount":999.00, "timeline":[{"state":"CONFIRMED", "at":"..."}] }
```

3. Standard Error Format

```
{ "code": "OUT_OF_STOCK", "message": "Item sold out", "requestId": "c0a8...", "retryable": false }
```

Code	HTTP	Retryable
VALIDATION_ERROR	400	no
UNAUTHENTICATED / FORBIDDEN	401 / 403	no
OUT_OF_STOCK / LIMIT_EXCEEDED / SALE_NOT_ACTIVE	409	no
RESERVATION_EXPIRED	409	no
IDEMPOTENCY_KEY_CONFLICT	422	no
RATE_LIMITED	429	yes (after Retry-After)
DEPENDENCY_UNAVAILABLE	503	yes
GATEWAY_TIMEOUT	504	yes (poll status)

4. API Rules

- Versioned path (/v1), backward-compatible changes only.
- Idempotency records stored 24 h; same key + same body → same response; same key + different body → 422.
- Pagination on list endpoints (limit , cursor).
- Input validated at gateway (schema) and service (business rules); no card data ever touches SALESTORM servers (tokenised by gateway SDK).
- Per-user rate limit (e.g. 5 reserve req/s) and per-IP limit at gateway.